

Week 3 — Attack Simulation and Detection Engineering

Overview

Week 3 focused on simulating three real-world attack scenarios from Kali Linux against the Windows 10 endpoint, capturing the resulting telemetry in Splunk, and building detection logic for each scenario.

Scenario	Tool	MITRE Technique
Network Reconnaissance	Nmap	T1046
Brute Force Authentication	Hydra	T1110
Reverse Shell via Social Engineering	Metasploit and Fake Webpage	T1566, T1204, T1059, T1071

Pre-Attack Setup Issues and Resolutions

Issue 1 — Nmap Scanning Wrong IP Address

Problem: Initial nmap scans targeted 10.0.2.15, which is the VirtualBox NAT address assigned to the Kali VM itself. The scan effectively scanned Kali against itself and returned all ports filtered after over 200 seconds.

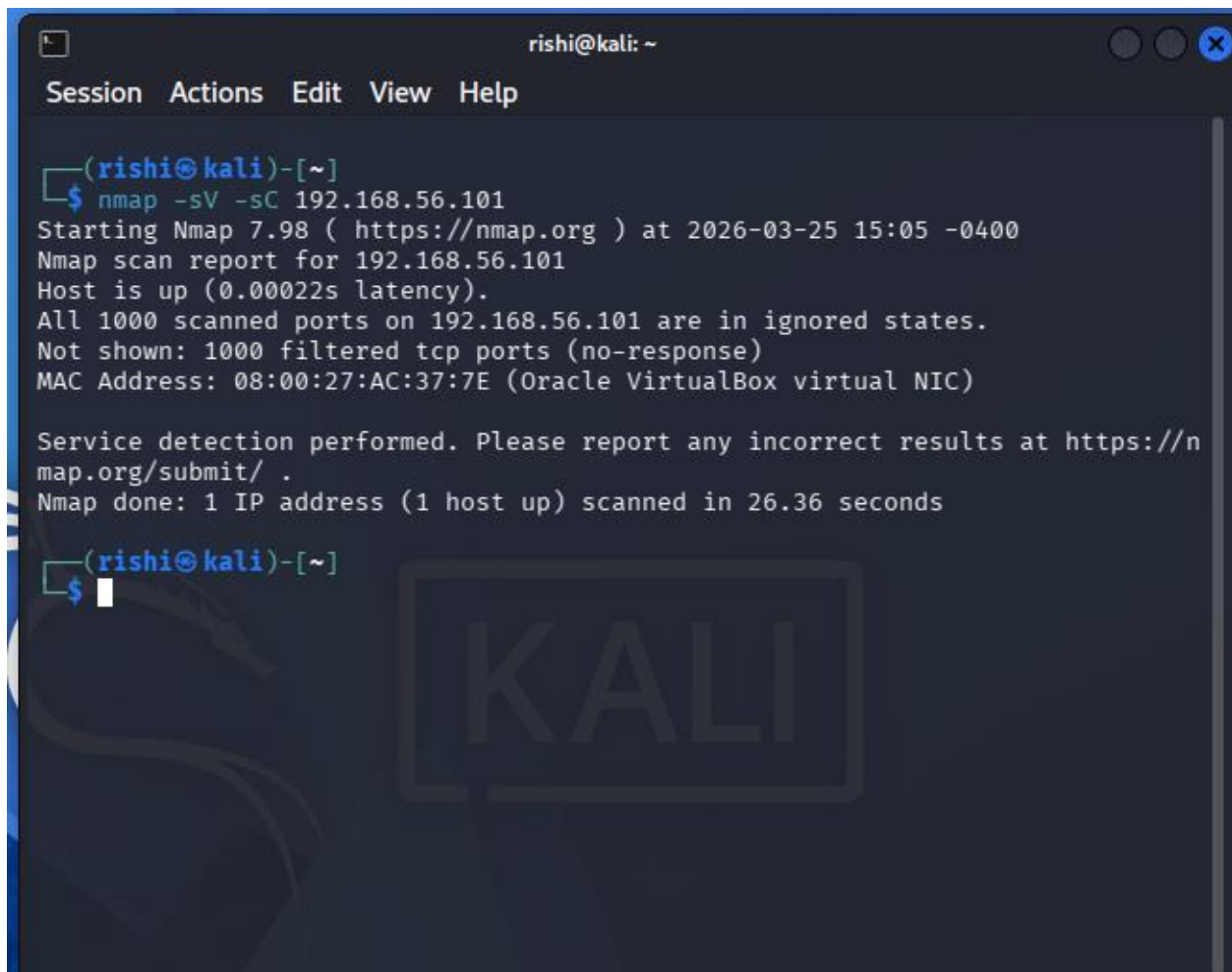
Root Cause: Both VMs were on NAT networking and could not communicate with each other.

Resolution: A Host-Only adapter was added to both VMs via VirtualBox Network Manager using vboxnet0. Both VMs then received 192.168.56.x addresses and inter-VM communication was established.

Issue 2 — Windows Firewall Blocking Nmap

Problem: Even with correct networking in place, the first nmap scan against 192.168.56.101 returned all 1000 ports as filtered:

All 1000 scanned ports on 192.168.56.101 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)



```
rishi@kali: ~  
Session Actions Edit View Help  
(rishi@kali)-[~]  
$ nmap -sV -sC 192.168.56.101  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-25 15:05 -0400  
Nmap scan report for 192.168.56.101  
Host is up (0.00022s latency).  
All 1000 scanned ports on 192.168.56.101 are in ignored states.  
Not shown: 1000 filtered tcp ports (no-response)  
MAC Address: 08:00:27:AC:37:7E (Oracle VirtualBox virtual NIC)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 26.36 seconds  
(rishi@kali)-[~]  
$
```

Fig 1: nmap scan on ports that failed due to firewall

Root Cause: Windows Firewall was dropping all inbound port probe packets from Kali.

Command used to resolve:

```
netsh advfirewall set allprofiles state off
```

Real World Note: In a real enterprise environment, filtered ports indicate a hardened host or network-level filtering. An attacker would use evasion techniques or target only known-open ports. For this lab, the firewall was disabled to focus on telemetry collection and detection engineering rather than evasion.

Issue 3 — Splunk Forwarder Pointing to Old IP

Problem: After networking changes, the forwarder was still sending logs to the old IP address 10.0.0.200 and no data was reaching Splunk.

Resolution: The outputs.conf file was updated to 192.168.56.1:9997 and the forwarder was restarted.

Scenario 1 — Network Reconnaissance

MITRE ATT&CK Mapping

Tactic	Technique	ID
Discovery	Network Service Discovery	T1046

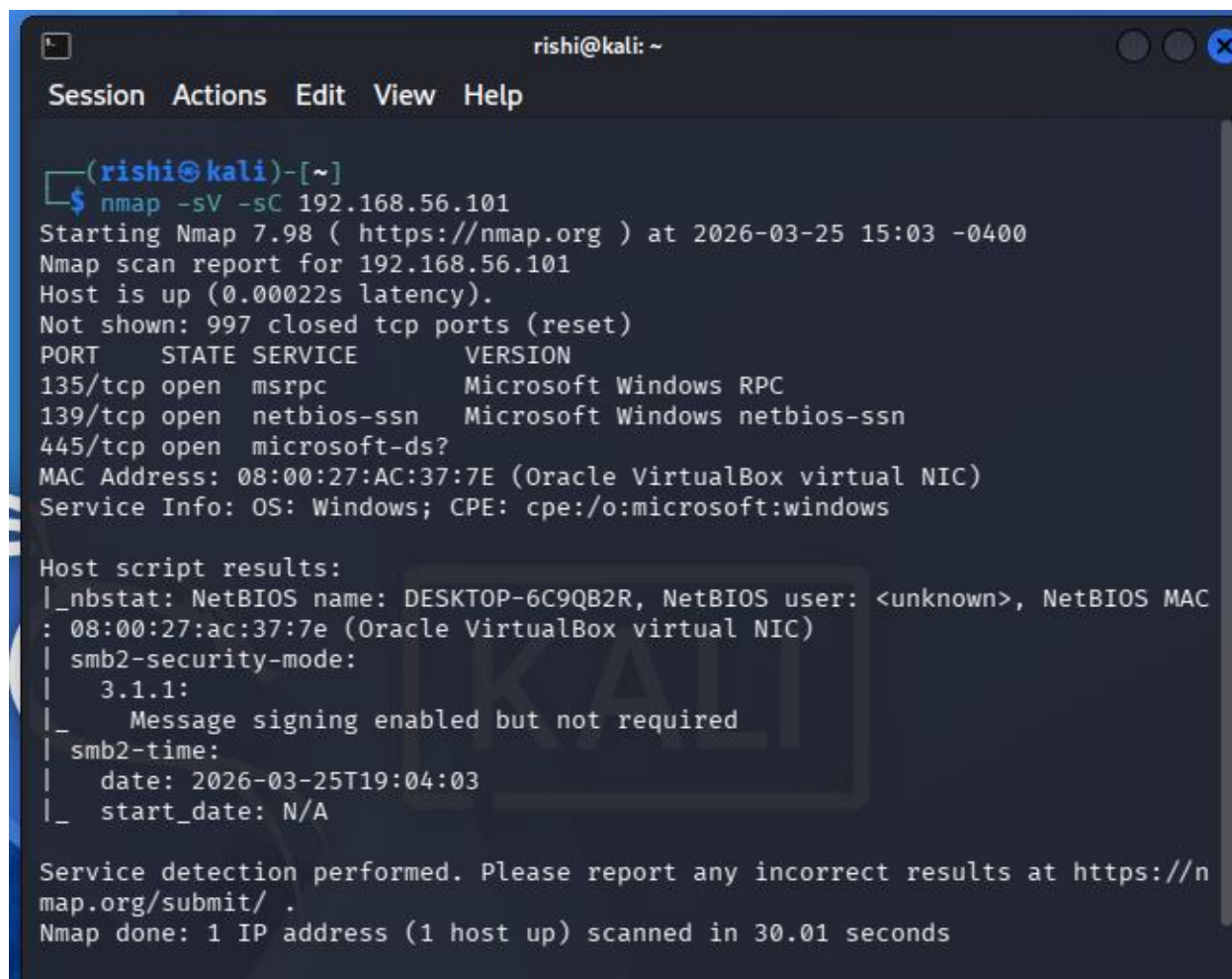
Objective

Simulate an attacker performing network service discovery to identify open ports and running services on the target Windows endpoint prior to launching further attacks.

Commands Executed on Kali

```
nmap -sV -sC 192.168.56.101
```

Results



```
(rishi@kali)-[~]
$ nmap -sV -sC 192.168.56.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-25 15:03 -0400
Nmap scan report for 192.168.56.101
Host is up (0.00022s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
MAC Address: 08:00:27:AC:37:7E (Oracle VirtualBox virtual NIC)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

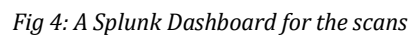
Host script results:
|_ nbstat: NetBIOS name: DESKTOP-6C9QB2R, NetBIOS user: <unknown>, NetBIOS MAC
: 08:00:27:ac:37:7e (Oracle VirtualBox virtual NIC)
|_ smb2-security-mode:
|   3.1.1:
|_   Message signing enabled but not required
|_ smb2-time:
|   date: 2026-03-25T19:04:03
|_   start_date: N/A

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 30.01 seconds
```

Fig 2: Successful nmap scan on ports

Sysmon EventID 3 (Network Connection) captured multiple inbound connection attempts from 192.168.56.102 across different destination ports within a short time window. Total events generated: 43 Sysmon EventID 3 events.

Fig 3: Port scan caught by Splunk



Analysis

Multiple connection attempts from a single source IP to different destination ports within a short time window is consistent with automated port scanning behavior. Port 445 (SMB) received the highest number of probes, indicating the attacker was particularly interested in file sharing and lateral movement opportunities.

Scenario 2 — Brute Force Authentication

MITRE ATT&CK Mapping

Tactic	Technique	ID
Credential Access	Brute Force	T1110

Objective

Simulate repeated credential guessing against an RDP service to generate authentication failure telemetry and validate detection logic in Splunk.

Issues Encountered

Issue 1 — RDP Not Listening

netstat -an returned no output for port 3389.

Resolution:

```
Set-ItemProperty -Path 'HKLM:\System\CurrentControlSet\Control\Terminal
Server' -name "fDenyTSConnections" -value 0
Enable-NetFirewallRule -DisplayGroup "Remote Desktop"
Start-Service TermService
Set-Service TermService -StartupType Automatic
```

After a VM restart, port 3389 confirmed listening:

```
TCP    0.0.0.0:3389    0.0.0.0:0      LISTENING
TCP    [::]:3389      [::]:0         LISTENING
```

Issue 2 — NLA Blocking Hydra

Error observed:

```
[ERROR] freerdp: The connection failed to establish.
[ERROR] all children were disabled due too many connection errors
```

Root Cause: Network Level Authentication requires authentication to be completed before the RDP session is established. Hydra's RDP module cannot complete NLA handshakes.

Resolution:

```
Set-ItemProperty -Path 'HKLM:\System\CurrentControlSet\Control\Terminal
Server\WinStations\RDP-Tcp' -name "UserAuthentication" -value 0
```

Issue 3 — Audit Policy Disabled, No 4625 Events

After running Hydra, no EventCode 4625 events appeared in Splunk.

Verification:

```
Get-WinEvent -LogName Security -MaxEvents 10 | Where-Object {$_.Id -eq 4625}
```

This returned nothing, confirming Windows itself was not generating the events.

Root Cause: Windows 10 audit policy for logon events is disabled by default.

Resolution:

```
auditpol /set /subcategory:"Logon" /failure:enable
auditpol /set /subcategory:"Logon" /success:enable
```

Issue 4 — Events Appearing in Wrong Log Source

4625 events were appearing sourced from WinEventLog:Application rather than WinEventLog:Security. These were unrelated application events sharing the same event code number.

Resolution: All searches scoped explicitly to the Security log:

```
index=windows source="WinEventLog:Security" EventCode=4625
```

Test Account Setup

A dedicated test account was created as the brute force target called labuser

Custom Wordlist on Kali

```
nano ~/labwordlist.txt
```

Contents:

```
welcome1
password
123456
letmein
summer2024
monkey
Password123 (The actual password for labuser)
```

Password123 was placed at the bottom to ensure multiple failures were generated before the successful login.

Attack Execution

```
hydra -l labuser -P ~/labwordlist.txt rdp://192.168.56.101 -t 2 -W 5
```

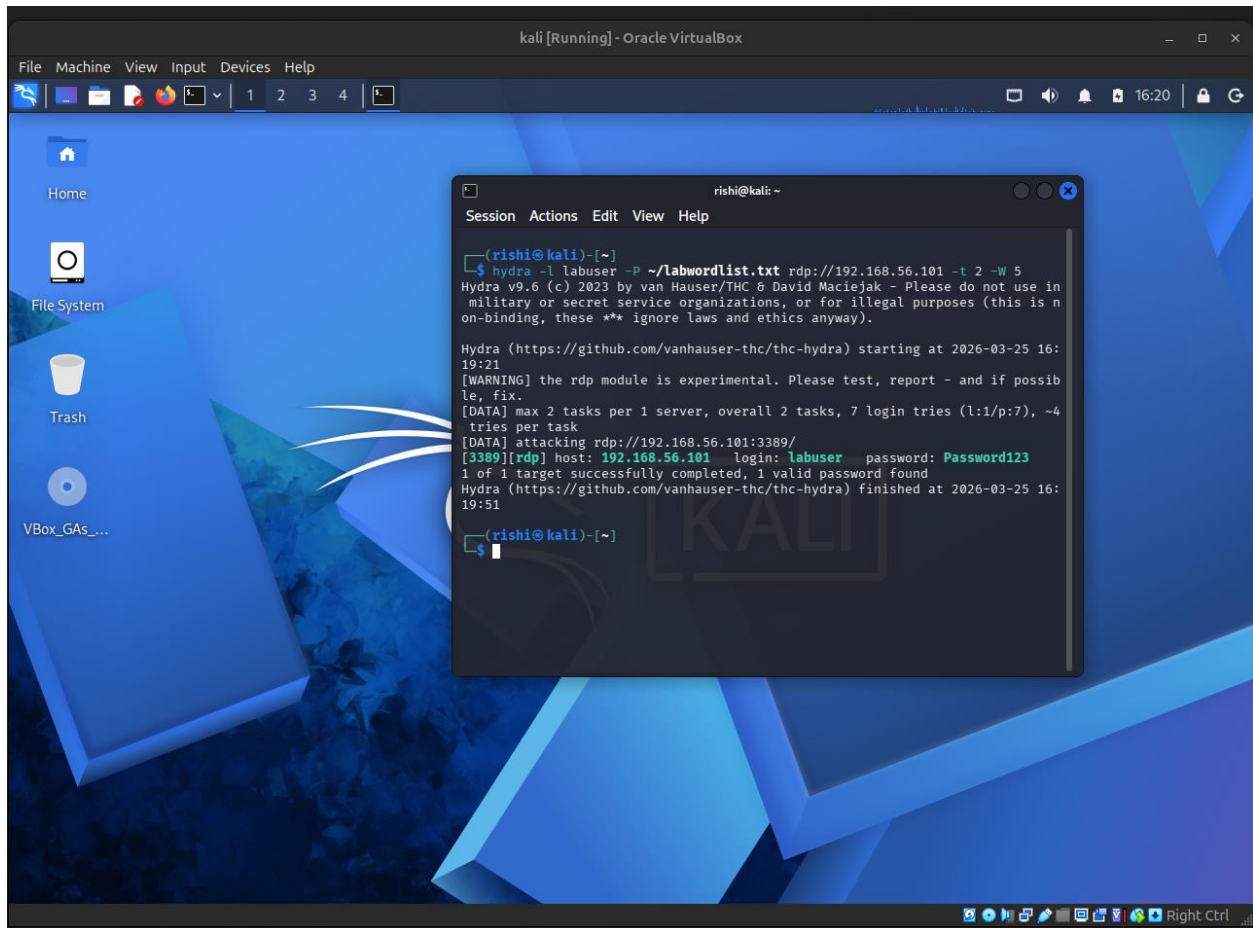


Fig 5: Successful Hydra attack

Logs Generated

Event ID	Description	Count
4625	Failed logon attempts	6
4624	Successful logon	1

Splunk Detection Queries

See all failed logins from Kali:

```
index=windows source="WinEventLog:Security" EventCode=4625
| table _time host Account_Name Source_Network_Address Logon_Type
| sort _time
```

New Search

Convert to SQL

Save All

Create Table View

Close

```
Index window source "WinEventLog\Security" EventCode 4625
| filter _type host Network_name SourceNetwork_Address Login_Type
| sort _time
```

Time range: Last 24 hours

9 events (2/24/26 4:00:00:000 PM to 3/25/26 4:27:21:000 PM)

No Parent Sampling

Join

Smart Mode

Events

Problems

Statistics (9)

VisualEditor

Show: 20 Per Page

Format

Preview On

Line #	Host #	Account_Name #	Source_Network_Address #	Login_Type #
0:0-0:1-25 16:25:11.733	SQLSRV-6C9B08	SQLSRV-6C9B08	127.0.0.1	1
0:0-0:25 16:25:13.480	SQLSRV-6C9B08	SQLSRV-6C9B08	127.0.0.1	2
0:0-0:25 16:25:14.580	SQLSRV-6C9B08	SQLSRV-6C9B08	127.0.0.1	2
0:0-0:1-25 16:25:16.228	SQLSRV-6C9B08	-	192.168.56.192	3
0:0-0:25 16:25:16.338	SQLSRV-6C9B08	Labuser	192.168.56.192	3
0:0-0:1-25 16:25:16.364	SQLSRV-6C9B08	-	192.168.56.192	3
0:0-0:25 16:26:06.268	SQLSRV-6C9B08	Labuser	192.168.56.192	3
0:0-0:25 16:26:09.422	SQLSRV-6C9B08	-	192.168.56.192	3
0:0-0:1-25 16:26:10.644	SQLSRV-6C9B08	Labuser	192.168.56.192	3

Fig 6: Failed Login Attempts

Full authentication timeline — failures and success together:

```
index=windows source="WinEventLog:Security" (EventCode=4624 OR
EventCode=4625)
| table _time host Account_Name EventCode Source_Network_Address Logon_Type
| sort _time
```

[illegible]

Fig 7: Successful and Failed Login Attempts

Strongest detection — failures followed by a successful login:

```
index=windows source="WinEventLog:Security" (EventCode=4624 OR
EventCode=4625)
| stats count(eval(EventCode=4625)) as failures,
          count(eval(EventCode=4624)) as successes
  by Source_Network_Address Account_Name
| where failures >= 5 AND successes >= 1
| eval verdict="Possible brute force with successful access"
| sort - failures
```

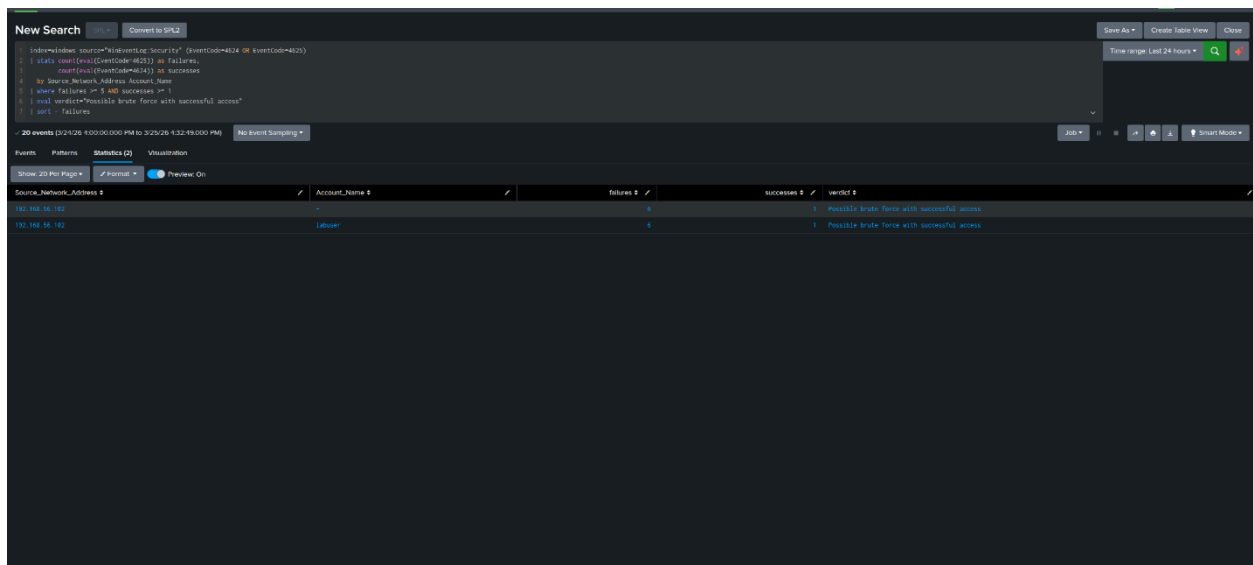



Fig 8: Successful Login after Multiple Failed attempts

Timechart to visualize the attack window:

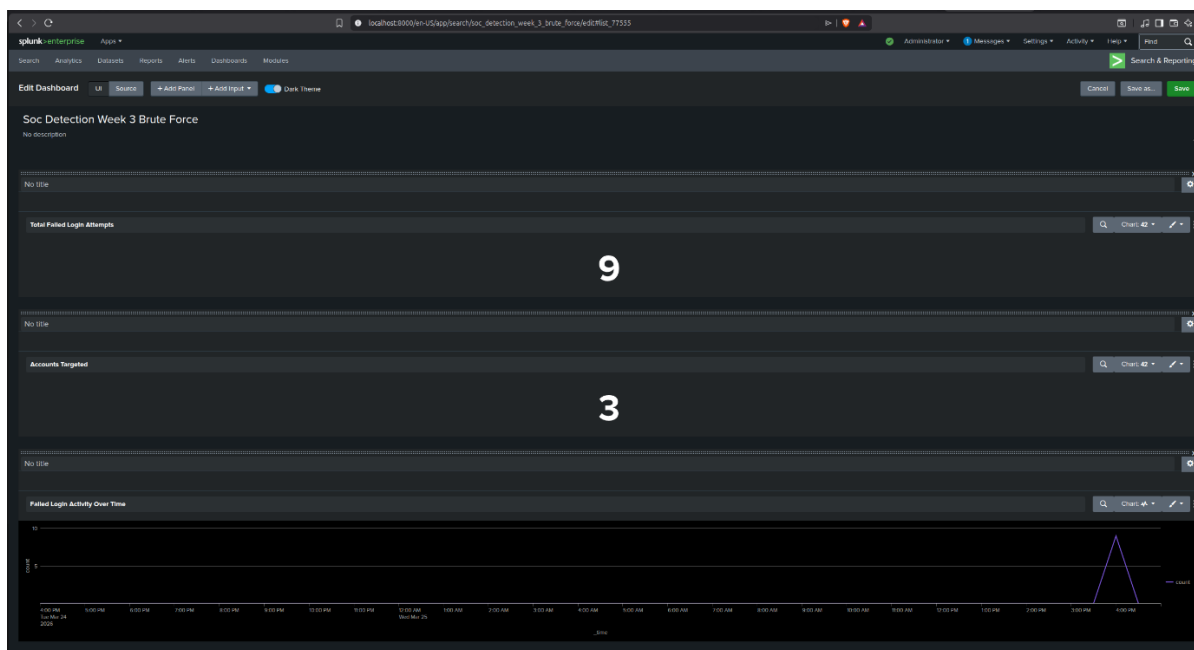


Fig 9: Dashboard 1 for the attack

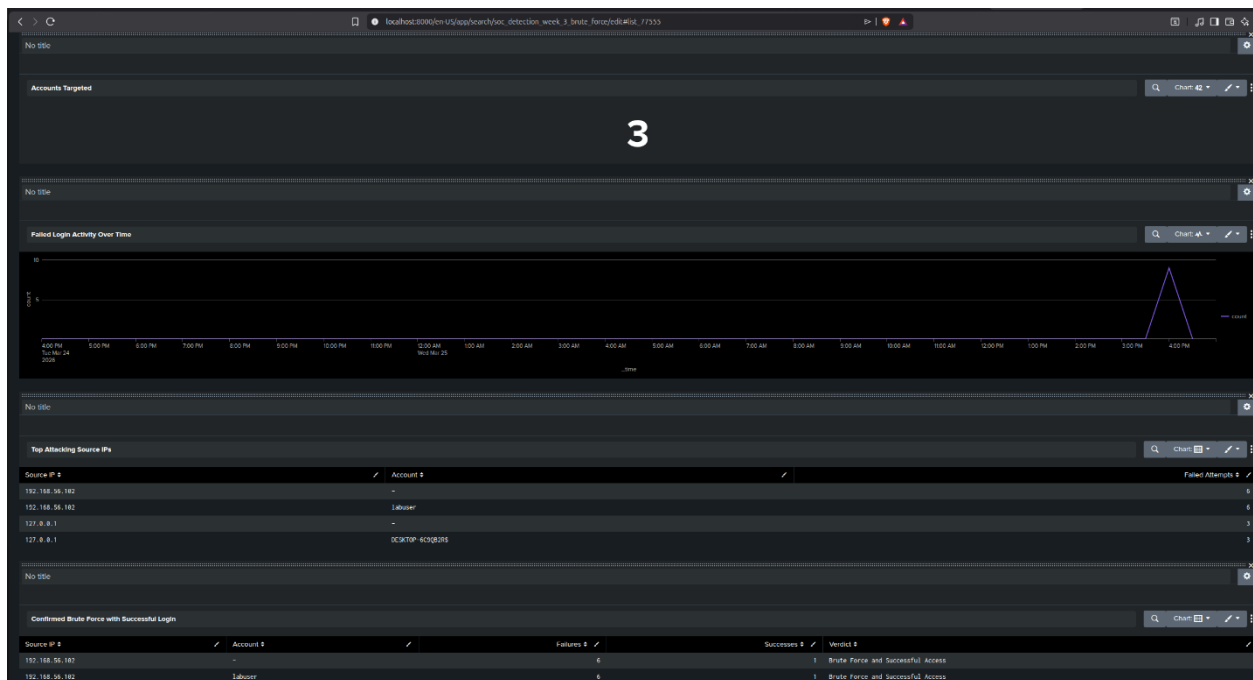


Fig 10: Dashboard 2 for the attack

A low avg_seconds_between value indicates automated tooling. A high value suggests a user forgetting their password. This distinction is important for reducing false positives in production environments.

Analysis

The Splunk query confirmed that 192.168.56.102 (Kali) generated 6 failed login attempts against the labuser account followed by 1 successful login. This pattern is consistent with automated credential guessing tools and would trigger an alert in a production SOC environment.

Scenario 3 — Reverse Shell via Social Engineering

MITRE ATT&CK Mapping

Tactic	Technique	ID
Initial Access	Phishing	T1566
Execution	User Execution	T1204
Execution	Command and Scripting Interpreter	T1059
Command and Control	Application Layer Protocol	T1071

Objective

Simulate a full attack chain in which a victim is deceived into downloading and executing a malicious payload via a fake webpage, establishing a reverse shell connection back to the attacker.

Attack Chain

1. Attacker generates payload using msfvenom
2. Attacker creates a fake webpage with a download link
3. Attacker hosts the page using Python HTTP server
4. Victim visits the page and downloads RAMBooster.exe
5. Victim executes the payload
6. Reverse TCP connection established from Windows to Kali on port 4444
7. Attacker receives Meterpreter session and executes commands
8. Splunk detects outbound C2 connection and suspicious process execution

Payload Generation on Kali

A payload was generated using msfvenom for a reverse_tcp shell script to our attack machine. The payload is called RAMBooster.exe

Fake Webpage

A social engineering delivery page was created in index.html and hosted alongside RAMBooster.exe. The page presented a fake “Download More RAM” tool to trick the victim into downloading the payload.

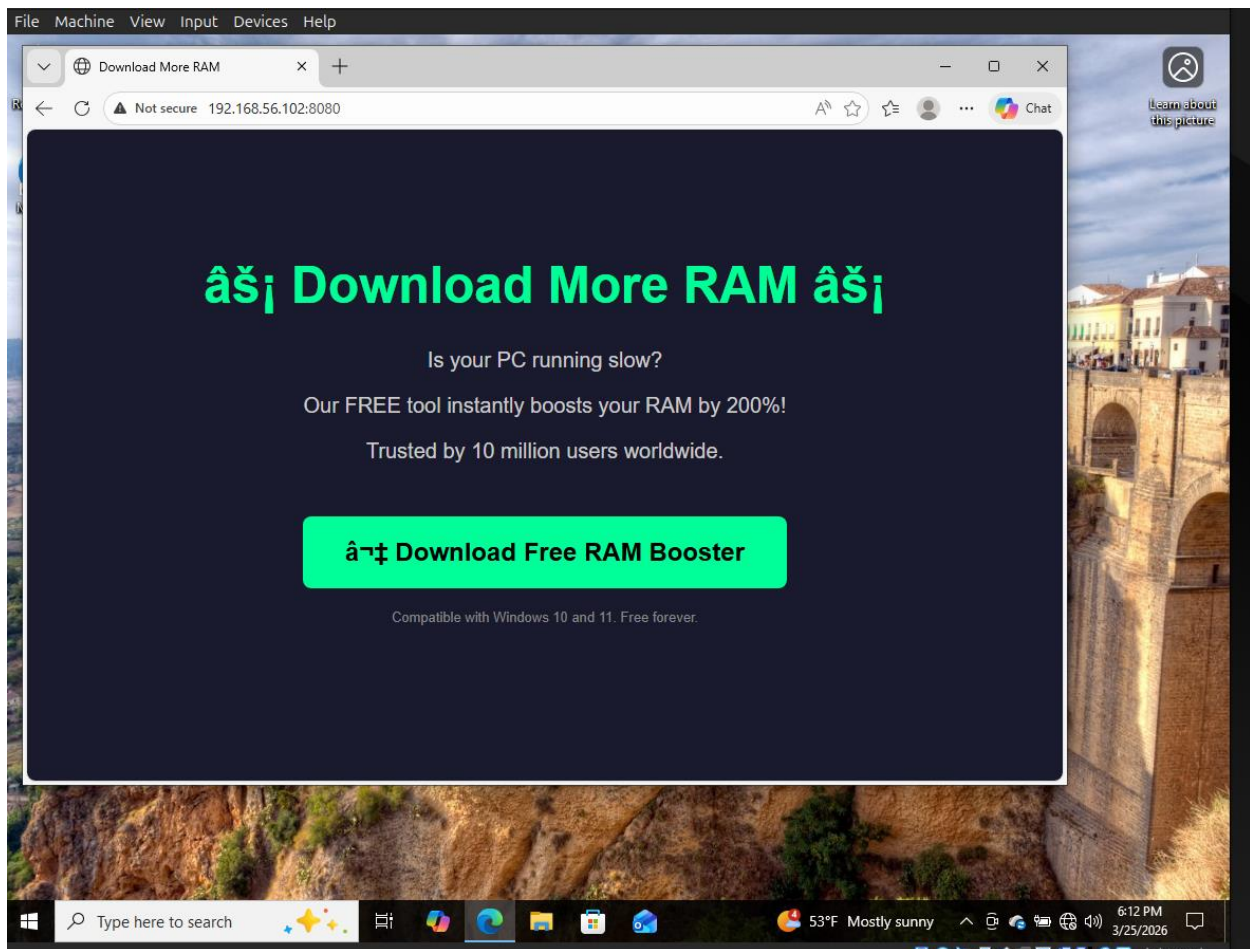


Fig 11: A phishing website that has the malicious payload

Python HTTP Server

```
python3 -m http.server 8080
```

The page was served at <http://192.168.56.102:8080> and confirmed accessible from the Windows VM browser. HTTP server logs confirmed successful requests from 192.168.56.101 for the RAMBooster.exe file.

Windows Defender

Windows Defender blocked the payload on initial execution. Real-time protection was disabled for the lab:

```
Set-MpPreference -DisableRealtimeMonitoring $true
```

Metasploit Listener Setup

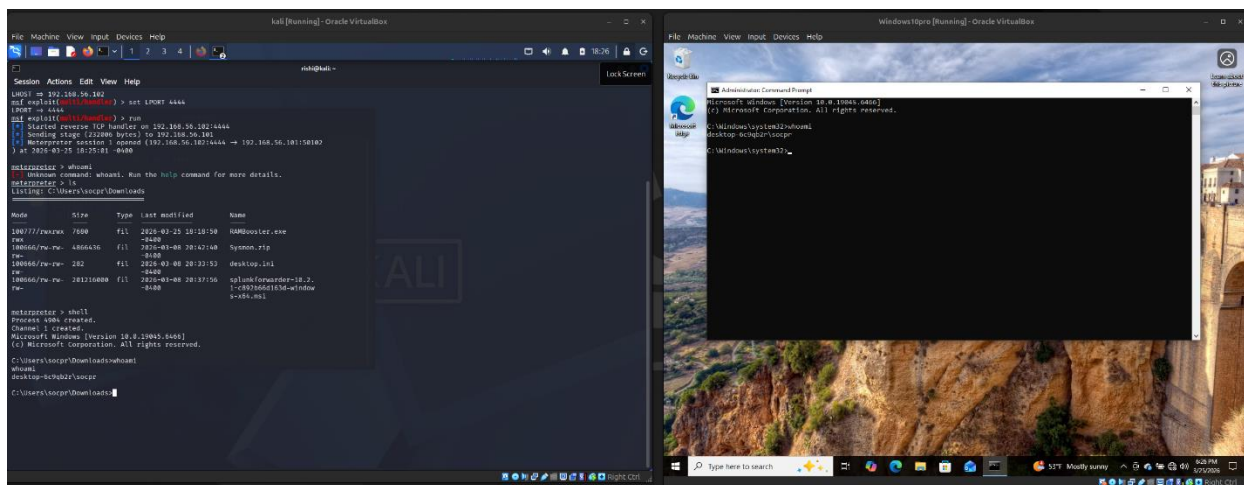


Fig 12: Successful execution of the payload

Logs Generated

Source	Event ID	Description
Sysmon	3	Outbound connection from RAMBooster.exe to 192.168.56.102:4444
Sysmon	3	PowerShell.exe outbound connection to 192.168.56.102:4444
Windows	4688	cmd.exe process created by payload

Splunk Detection Queries

Detect outbound C2 connection to Kali:

```
index=windows EventCode=3 DestinationIp=192.168.56.102
| table _time Image SourceIp DestinationIp DestinationPort
| sort _time
```

Detect connections specifically on port 4444:

```
index=windows EventCode=3
| stats count by DestinationIp DestinationPort Image
| where DestinationPort=4444
| eval Verdict="Suspicious C2 Port"
```

Detect suspicious process execution:

```
index=windows EventCode=4688
| table _time New_Process_Name Creator_Process_Name
| search New_Process_Name="*cmd.exe" OR New_Process_Name="*powershell.exe"
| sort _time
```

Full attack event timeline:

```
index=windows (EventCode=4688 OR EventCode=3 OR EventCode=11)
| eval EventType=case(
    EventCode=4688, "Process Created",
    EventCode=3,    "Network Connection",
    EventCode=11,   "File Created",
    true(),         "Other")
| table _time EventType Image DestinationIp DestinationPort TargetFilename
| sort _time
```

Reverse shell detection alert — confirmed C2:

```
index=windows EventCode=3 DestinationIp=192.168.56.102 DestinationPort=4444
| stats count by Image DestinationIp DestinationPort
| eval Verdict="Confirmed Reverse Shell C2 Activity"
| eval MITRE="T1059 + T1071"
```

Dashboard Results

The reverse shell detection dashboard confirmed:

- Total C2 connections to Kali: 14
- Processes connecting to attacker IP: RAMBooster.exe and powershell.exe both on port 4444
- Suspicious process execution: RAMBooster.exe spawning cmd.exe and PowerShell.exe
- Outbound connections on suspicious ports: 192.168.56.102:4444 flagged with verdict "Suspicious Outbound Port"
- Detection alert panel confirmed T1059 and T1071 for both RAMBooster.exe and powershell.exe

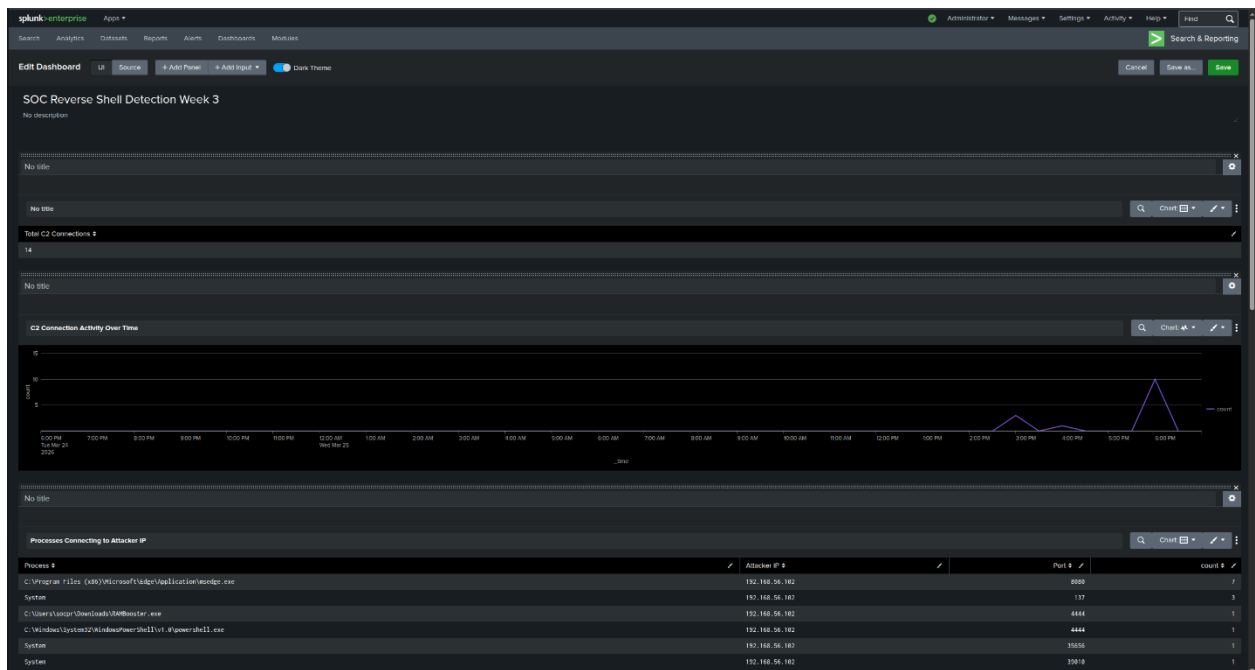


Fig 13: Dashboard 1 for the Reverse Shell via Social Engineering Attack

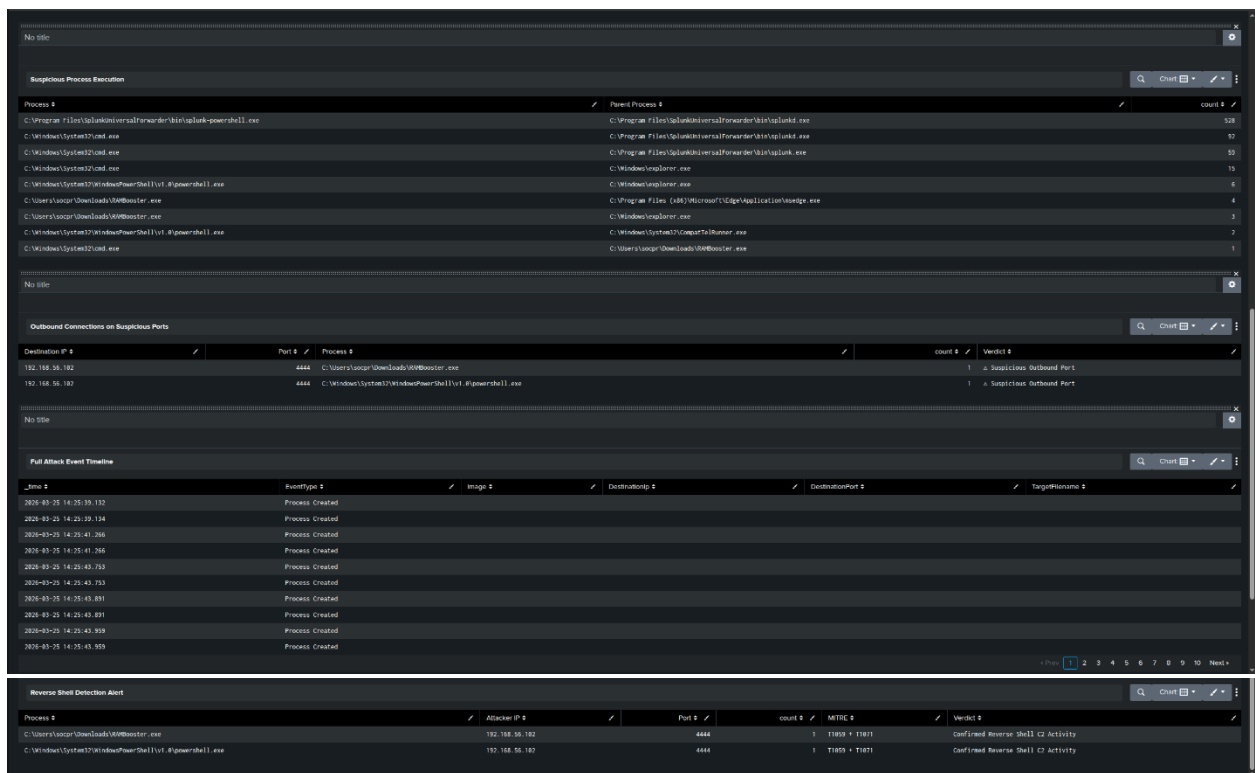


Fig 14: Dashboard 2 for the Reverse Shell via Social Engineering Attack

Analysis

The detection confirmed the full attack chain. RAMBooster.exe was written to the Downloads directory, executed by the user, established an outbound connection to the attacker IP on port 4444, and spawned a Windows command shell. All three detection layers — file creation, network connection, and process execution — fired successfully.

Week 3 Summary — Issues and Resolutions

Issue	Root Cause	Resolution
Nmap scanning wrong IP	VMs on NAT network	Added Host-Only adapter to both VMs
Nmap ports all filtered	Windows Firewall blocking scans	netsh advfirewall set allprofiles state off
RDP not listening	RDP service disabled	Enabled via registry and service start
Hydra connection failing	NLA blocking RDP module	Disabled NLA via registry
No 4625 events in Splunk	Audit policy disabled by default	auditpol set Logon subcategory enabled
4625 in wrong log source	Application log vs Security log	Scoped all searches to WinEventLog:Security
Payload blocked on execution	Windows Defender real-time protection	Disabled via Set-MpPreference

MITRE ATT&CK Coverage — Week 3

Attack	Tactic	Technique	ID
Nmap port scan	Discovery	Network Service Discovery	T1046
Hydra RDP brute force	Credential Access	Brute Force	T1110
Fake webpage delivery	Initial Access	Phishing	T1566
User downloads payload	Execution	User Execution	T1204
Meterpreter shell	Execution	Command and Scripting Interpreter	T1059
C2 over port 4444	Command and Control	Application Layer Protocol	T1071

Key Lessons Learned

- 1. Audit policy is disabled by default.** Windows 10 does not log authentication failures without explicit audit policy configuration. This is a common enterprise misconfiguration that leaves credential attacks completely undetected in the Security log.
- 2. Social engineering changes the attack profile.** Adding a fake webpage introduced T1566 and T1204 to the MITRE mapping, making the attack chain significantly more realistic and the documentation stronger than a plain payload drop.
- 3. Parent-child process relationships are strong indicators.** RAMBooster.exe spawning cmd.exe and powershell.exe is far more meaningful than seeing cmd.exe run in isolation. Relationship-based detection is harder to evade than single-process detection.
- 4. Port 4444 is a reliable C2 indicator in this environment.** No legitimate Windows process made outbound connections on port 4444 during the baseline period established in Week 2. Any such connection is immediately actionable.